

Plantilla de Excel para Cálculo del IGM y ROI de Ciberseguridad

Especificación Técnica para Implementación

Kit COSO-Ciber v2025.1

"Lo que no se puede medir en euros rara vez llega al orden del día del Comité de Dirección. Esta plantilla construye el puente entre el lenguaje ciber y el lenguaje del CFO."

Descripción General

La presente especificación describe la estructura de la **Plantilla Excel de Cálculo del Índice Global de Madurez (IGM) y el Retorno sobre la Inversión en Seguridad (ROSI/ROI-Ciber)**, diseñada para implementarse directamente en Microsoft Excel o en cualquier hoja de cálculo compatible (Google Sheets, LibreOffice Calc).

Nombre del archivo: COSO_Ciber_IGM_ROI_v2025.xlsx

Hojas incluidas: 8 pestañas interconectadas (índice a continuación)

Estructura de Pestañas

#	Nombre de la Pestaña	Color	Propósito
1	 INICIO	Azul oscuro	Portada, instrucciones de uso y navegación
2	 DATOS_ENCUESTA	Gris	Entrada de datos de la encuesta (manual o importación CSV)
3	 CONVERSIÓN	Amarillo	Tabla de conversión de respuestas categóricas a puntuaciones numéricas
4	 IGM_CÁLCULO	Verde	Cálculo del IGM por componente COSO y puntuación global
5	 ROI_ROSI	Naranja	Módulo de cuantificación financiera del riesgo y cálculo ROSI
6	 DIAGNÓSTICO	Rojo/Verde	Semáforo de estado por IAT y recomendaciones priorizadas
7	 DASHBOARD	Azul claro	Cuadro de mando visual (gráficos de radar, barras, indicadores)
8	 INFORME	Blanco	Plantilla de informe ejecutivo generado automáticamente

Pestaña 1: INICIO

Campos de Cabecera

Organización: [Campo editable]
Sector de actividad: [Desplegable – 14 opciones según P-0.2]
Fecha de evaluación: [Fecha automática + campo editable]
Evaluador/a: [Campo editable]
Versión del kit: COSO-Ciber v2025.1

Instrucciones de Uso (texto)

PASO 1 → Ir a pestaña DATOS_ENCUESTA e introducir las respuestas de la encuesta
PASO 2 → La pestaña CONVERSIÓN convierte automáticamente respuestas a puntuaciones numéricas
PASO 3 → La pestaña IGM_CÁLCULO calcula el Índice Global de Madurez automáticamente
PASO 4 → Si dispone de datos financieros, completar la pestaña ROI_ROSI para el cálculo del ROSI
PASO 5 → Revisar el DIAGNÓSTICO y las recomendaciones priorizadas
PASO 6 → El DASHBOARD genera visualizaciones automáticas con los datos introducidos
PASO 7 → La pestaña INFORME genera un borrador de reporte ejecutivo listo para presentar

Pestaña 2: DATOS_ENCUESTA

Estructura (columnas)

Columna	Cabecera	Tipo	Validación
A	Código_Pregunta	Texto	Lista (P-0.1 ... P-10.4)
B	Bloque	Texto	Lista (0, I, II, ... X)
C	Respuesta_Código	Texto	Lista según opciones de cada pregunta
D	Respuesta_Texto	Texto	Autocompletado desde tabla de lookup
E	Puntuación_Asignada	Número (1-5)	Fórmula desde pestaña CONVERSIÓN
F	Es_IAT	Sí/No	Fórmula (SI código en lista_IATs, "Sí", "No")
G	Notas	Texto libre	Campo editable

Tabla de Entrada de Datos (filas por pregunta)

Filas P-0.1 a P-10.4 (59 preguntas). Las columnas E y F se calculan automáticamente.

Pestaña 3: CONVERSIÓN

Tabla de Conversión de Respuestas a Puntuaciones (1-5)

Preguntas de Escala Directa (1-5)

Para preguntas como P-2.1, P-6.1, P-8.2: la puntuación es igual al valor seleccionado.

Preguntas de Selección Única con Escala Implícita

Ejemplo: P-1.1 (Supervisión del consejo)

Respuesta	Código	Puntuación
En cada sesión del consejo	A	5
Trimestralmente	B	4
Semestralmente	C	3
Anualmente	D	2
Solo ante incidentes	E	1
El Consejo no revisa el ciberriesgo	F	1
No existe Consejo formal	G	N/A

Ejemplo: P-3.3 (Time-to-Patch)

Respuesta	Código	Puntuación
< 24 horas	A	5
1-7 días	B	4
8-30 días	C	3
31-90 días	D	2
> 90 días	E	1
No se mide	F	1

Ejemplo: P-3.5 MTTD

Respuesta	Código	Puntuación
< 1 hora	A	5
1-8 horas	B	4
8-24 horas	C	3
1-7 días	D	2
> 7 días	E	1
No se mide	F	1

Preguntas de Selección Múltiple (puntuación por cobertura)

Puntuación = (Número de opciones seleccionadas / Número total de opciones posibles) $\times$ 4 + 1

= (CONTAR.SI(rango_respuestas, "Sí") / TOTAL OPCIONES) * 4 + 1

Preguntas de Tabla Matricial (escala 1-5)

Puntuación = Media aritmética de las puntuaciones de cada fila de la tabla.

= PROMEDIO(fila1, fila2, fila3, ..., filaN)

Pestaña 4: IGM_CÁLCULO

Estructura de Cálculo

CÁLCULO DEL IGM				
Componente COSO	Peso IGM	Preguntas	Prom. Comp.	Aportación IGM
C-I Gobernanza	25%	P-1.1→P-1.8	=PROMEDIO()	=Prom × 0,25
C-II Estrategia	20%	P-2.1→P-2.6	=PROMEDIO()	=Prom × 0,20
C-III Desempeño	30%	P-3.1→P-3.11	=PROMEDIO()	=Prom × 0,30
C-IV Revisión	10%	P-6.1→P-6.5	=PROMEDIO()	=Prom × 0,10
C-V Reporte	15%	P-7.1→P-7.4	=PROMEDIO()	=Prom × 0,15
IGM TOTAL	100%			=SUMA(aportes)

Fórmulas Excel Clave

```
// Puntuación media Componente I (Gobernanza)
=PROMEDIO(DATOS_ENCUESTA!E2:E9)

// IGM Total
=DATOS_ENCUESTA!E_C1*0.25 + DATOS_ENCUESTA!E_C2*0.20 + DATOS_ENCUESTA!E_C3*0.30
+ DATOS_ENCUESTA!E_C4*0.10 + DATOS_ENCUESTA!E_C5*0.15

// Clasificación del IGM (fórmula anidada)
=SI(IGM<2,"CRÍTICO 🚫",SI(IGM<3,"EMERGENTE 🟡",SI(IGM<4,"ESTABLECIDO 🟢",
SI(IGM<4.6,"AVANZADO 🟢", "LÍDER 🔵"))))

// Percentil del sector (si se dispone de datos de benchmark)
=PERCENTIL(datos_sector, posición_relativa)
```

Indicadores de Alerta Temprana (IAT) en esta pestaña

```
// Contar IATs en nivel crítico (puntuación ≤ 2)
=CONTAR.SI.CONJUNTO(DATOS_ENCUESTA!F:F,"Sí", DATOS_ENCUESTA!E:E,"<=2")

// Semáforo por IAT (formato condicional)
SI(puntuación<=2, fondo=ROJO, SI(puntuación<=3, fondo=NARANJA, fondo=VERDE))
```

Pestaña 5: ROI_ROSI

Módulo 1 — Cuantificación del Riesgo (metodología ALE / FAIR simplificado)

CUANTIFICACIÓN DEL RIESGO CIBER (por escenario)	
Campo	Valor / Fórmula
Nombre del escenario de riesgo SLE – Pérdida por evento único - Daños directos - Daños indirectos ARO – Frec. anual estimada **ALE = SLE × ARO**	[p.ej.: "Ransomware en ERP principal"] [€ – introducir estimación] [€ – restauración, forense, lucro cesante] [€ – reputación, multas, litigios] [nº eventos / año – puede ser decimal] =SLE_directos + SLE_indirectos × ARO
ALE SIN control (exposición base) Reducción de riesgo del control ALE CON control Riesgo reducido por el control	=ALE calculado arriba [% – p.ej.: MFA reduce ransomware 75%] =ALE_sin × (1 - reducción_%) =ALE_sin - ALE_con

Módulo 2 — Cálculo del ROSI

CÁLCULO DEL ROSI POR CONTROL	
Control de seguridad Coste anual del control Riesgo anual reducido (Δ ALE) **ROSI = (Δ ALE - Coste) / Coste** ROSI expresado en % Interpretación	[p.ej.: "Implementación MFA Universal"] [€ – licencias + implantación/12 meses] =ALE_sin - ALE_con =(riesgo_reducido - coste) / coste =ROSI × 100 SI(ROSI>0, "Inversión justificada  ", "Revisar coste-beneficio  ")
ROSI de cartera (todos controles)	=SUMA(ROSI_i × peso_i)

Módulo 3 — Comparativa Sector / Coste de Brecha

BENCHMARKING DE COSTE DE INCIDENTE	
Coste medio de brecha en el sector Coste medio de brecha global 2025 Coste estimado para su sector Prima de seguro de ciberriesgo Variación de prima por mejora IGM Ahorro en prima por mejora IGM	[€ – fuente: IBM Cost of Data Breach] \$4.88M USD (IBM 2025) – ajustar a € [€ – introducir dato sectorial] [€/año – si aplica] [% – estimado con asegurador] =prima_actual × variación_%

Módulo 4 — Cuadro de Mando ROI Ejecutivo

CUADRO DE MANDO ROI EJECUTIVO	
Inversión total ciber/año	[€ – presupuesto total del programa]
ALE total SIN programa	=SUMA(ALE_sin por todos los escenarios)
ALE total CON programa	=SUMA(ALE_con por todos los escenarios)
Riesgo total reducido	=ALE_sin_total - ALE_con_total
ROI del programa	=(riesgo_reducido - inversión) / inversión × 100
Payback period	=inversión / (riesgo_reducido / 12) meses
IGM actual	=referencia a pestaña IGM_CÁLCULO
IGM objetivo (12 meses)	[introducir objetivo de mejora]

Pestaña 6: DIAGNÓSTICO

Semáforo de IATs

```
// Para cada una de las 14 preguntas IAT:
=SI(puntuación<=2, "● CRÍTICO – Acción inmediata requerida",
SI(puntuación=3, "● MEJORABLE – Incluir en plan de mejora",
SI(puntuación>=4, "● ADECUADO – Mantener y optimizar", "-")))
```

Tabla de Recomendaciones Priorizadas (generada automáticamente)

Ordenadas por: (1) IATs críticos – (2) IATs mejorables – (3) No-IATs críticos

Prioridad	Pregunta	Puntuación actual	Puntuación objetivo	Acción recomendada	Marco normativo clave
● 1	P-XX	1.0	3.0	[texto acción]	NIS2 Art. XX; COSO P-XX
...	...	...	...	...	...

Pestaña 7: DASHBOARD

Gráficos Incluidos (generados con datos de las otras pestañas)

- Gráfico de Radar (Spider Chart) del IGM — 5 ejes = 5 componentes COSO
- Barras comparativas — Puntuación por componente vs. benchmark sectorial (si disponible)
- Velocímetro/Gauge del IGM global (escala 1–5, colores rojo/naranja/amarillo/verde/azul)
- Semáforo de las 14 IATs — Grid 7×2 con indicador de color
- Barras horizontales de ROSI por control (ordenadas de mayor a menor)
- Línea de evolución del IGM (para ediciones sucesivas de la encuesta)

Instrucción de Implementación

Todos los gráficos se generan automáticamente al introducir datos en DATOS_ENCUESTA. Para el Gráfico de Radar:

```
// Datos del radar: referencias a IGM_CÁLCULO!C4:C8 (puntuaciones por componente)
// Eje máximo: 5
// Eje mínimo: 0
// Línea de referencia adicional (benchmark): datos externos si disponibles
```

Pestaña 8: INFORME

Plantilla de Texto con Referencias Dinámicas

El informe se genera automáticamente mediante fórmulas de concatenación de texto + datos:

```
// Título dinámico
="INFORME DE DIAGNÓSTICO COSO-CIBER – "&INICIO!B3&" – "&TEXT0(HOY()),"MMMM YYYY")

// Párrafo resumen ejecutivo
="La organización "&INICIO!B3&" ha obtenido un Índice Global de Madurez (IGM) de "&
TEXT0(IGM_CÁLCULO!B15,"0.0")&"/5.0, correspondiente al nivel "&IGM_CÁLCULO!B16&
". El componente de mayor fortaleza es "&IGM_CÁLCULO!B17&
", mientras que el de mayor oportunidad de mejora es "&IGM_CÁLCULO!B18&".

// Sección IATs
="Se han identificado "&DIAGNÓSTICO!B3&" indicadores de alerta temprana en nivel
crítico,
que requieren acción prioritaria en un horizonte de 0-90 días."
```

Consideraciones de Implementación

Requisitos Técnicos

- Microsoft Excel 2016 o superior / Google Sheets (con funcionalidades equivalentes)
- Para gráficos dinámicos avanzados: Excel 365 con SparkLines y Dynamic Arrays

Protección de la Plantilla

- Hojas CONVERSIÓN y fórmulas clave: protegidas con contraseña (solo datos_encuesta editable)
- Validaciones de datos activadas en columna C (Respuesta_Código)
- Mensajes de error configurados para respuestas fuera del rango válido

Escalabilidad

- La plantilla permite introducir datos de múltiples organizaciones para análisis comparativo de sector
- Tab adicional COMPARATIVA disponible para versión premium del kit

Fórmulas de Referencia Rápida

```
// ALE
```

```
=SLE * ARO
```

```
// ROI
```

```
=(ALE_sin_control - ALE_con_control - Coste_control) / Coste_control
```

```
// IGM
```

```
=(PROM_C1*0.25) + (PROM_C2*0.20) + (PROM_C3*0.30) + (PROM_C4*0.10) + (PROM_C5*0.15)
```

```
// Puntuación selección múltiple
```

```
=(CONTARSÍ_MARCADAS / TOTAL_OPCIONES) * 4 + 1
```

```
// IATs en estado crítico
```

```
=CONTAR.SI.CONJUNTO(columna_IAT, "Sí", columna_puntuacion, "<=2")
```

Plantilla Excel IGM y ROI — Kit COSO-Ciber v2025.1 | Abril 2026

Metodología ALE/SLE/ARO: NIST SP 800-30 Rev. 1 · Metodología FAIR: ANSI/OpenFAIR 2023 · IGM: COSO ERM 2017 + CMMI v2.0